	INSTITUT SUPERIEUR DES MATHEMATIQUES APPLIQUEES ET DE L'INFORMATIQUE DE KAIROUAN			
	Département	Département Informatique		
	Filière	Licence en Ingénierie des Systèmes Informatiques & Licence en Science Informatique (2ème Année)		
	Matière	Programmation Web		
	Année universitaire	2025/2026	TP8 : Version Amélioré du CMS	Hédi Nsibi

Exercice :

🎯 Objectifs pédagogiques

Partie 1 – Mise à jour de la base de données

Ajouter un rôle à la table users

```
ALTER TABLE users ADD role ENUM('admin', 'user') DEFAULT 'user';
```

👉 Exemple :

```
UPDATE users SET role='admin' WHERE id=1;
```

Partie 2 – Gestion des rôles

Vérification des droits (à inclure dans les pages admin)

```
<?php
session_start();

if (!isset($_SESSION['user_id']) || $_SESSION['role'] != 'admin') {
    die("Accès refusé");
}
?>
```

Modifier login.php (IMPORTANT)

```
$_SESSION['user_id'] = $user['id'];
$_SESSION['role'] = $user['role'];
```

Partie 3 – CRUD COMPLET des articles

1. Afficher les articles avec actions

📄 admin/dashboard.php

```
<?php include("../config/db.php"); ?>

<h2>Liste des articles</h2>

<?php
$result = $conn->query("SELECT * FROM articles");

while($row = $result->fetch_assoc()) {
    echo "<p>
        {$row['title']}
        <a href='edit_article.php?id={$row['id']}'>Modifier</a>
        <a
href='../actions/delete_article.php?id={$row['id']}'>Supprimer</a>
    </p>";
}
?>
```

2. Modifier un article

📄 admin/edit_article.php

```
<?php
include("../config/db.php");

$id = $_GET['id'];
$article = $conn->query("SELECT * FROM articles WHERE id=$id")-
>fetch_assoc();
?>

<form method="POST">
    <input type="text" name="title" value="<?php echo $article['title'];
?>">
    <textarea name="content"><?php echo $article['content']; ?></textarea>
    <button>Modifier</button>
</form>

<?php
if ($_POST) {
    $title = $_POST['title'];
    $content = $_POST['content'];

    $conn->query("UPDATE articles SET title='$title', content='$content'
WHERE id=$id");

    header("Location: dashboard.php");
}
?>
```

3. Supprimer un article

📄 `actions/delete_article.php`

```
<?php
include("../config/db.php");

$id = $_GET['id'];

$conn->query("DELETE FROM articles WHERE id=$id");

header("Location: ../admin/dashboard.php");
?>
```

Partie 4 – Sécurisation

❌ Problème actuel

```
WHERE id=$id
```

👉 Vulnérable à **SQL Injection**

Solution avec requêtes préparées

```
$stmt = $conn->prepare("DELETE FROM articles WHERE id=?");
$stmt->bind_param("i", $id);
$stmt->execute();
```

Partie 5 – Restriction selon rôle

Dans dashboard.php

```
if ($_SESSION['role'] == 'admin') {
    echo "<a href='add_article.php'>Ajouter</a>";
}
```

Empêcher suppression côté serveur

```
if ($_SESSION['role'] != 'admin') {
    die("Action interdite");
}
```

Partie 6 – Amélioration frontend

Afficher bouton modifier uniquement pour admin

```
if ($_SESSION['role'] == 'admin') {
    echo "<a href='edit_article.php?id={$row['id']}'>Modifier</a>";
}
```

🎯Résultat attendu

L'étudiant doit obtenir :

- ✅ CRUD complet (Create / Read / Update / Delete)
- ✅ Authentification fonctionnelle
- ✅ Gestion des rôles :
  - admin → accès total
  - user → lecture + commentaires uniquement
- ✅ Sécurisation basique